

STAGE 4

Semgrep taint path:

SRC="/home/user01/solr-8.11.0/solr-source"

R="/home/user01/solr-8.11.0/results"

RULE="\$R/log4shell-taint-semgrep.yml"

mkdir -p "\$R"

cat > "\$RULE" <<'EOF'

Rules:

- id: java-user-input-to-logger

mode: taint

languages:

- java

message: "User-controlled input may flow into a logging call."

severity: WARNING

pattern-sources:

- pattern: \$REQ.getHeader(...)
- pattern: \$REQ.getParameter(...)
- pattern: \$REQ.getQueryString()
- pattern: \$REQ.getRequestURI()
- pattern: \$REQ.getRequestURL()
- pattern: \$REQ.getRemoteAddr()
- pattern: \$REQ.getRemoteHost()
- pattern: \$REQ.getUserPrincipal()

- pattern: \$REQ.getParams()
- pattern: \$REQ.getParam(...)

pattern-sinks:

- pattern: \$LOG.trace(...)
- pattern: \$LOG.debug(...)
- pattern: \$LOG.info(...)
- pattern: \$LOG.warn(...)
- pattern: \$LOG.error(...)

EOF

Run Semgrep:

```
cd "$SRC"
```

```
semgrep scan \
```

```
--config "$RULE" \
```

```
--json \
```

```
--output "$R/section4-solr-semgrep-taint-results.json" \
```

```
solr
```

```
jq '.results | length' "$R/section4-solr-semgrep-taint-results.json" \
```

```
| tee "$R/section4-solr-semgrep-taint-count.txt"
```

```
jq -r '
```

```
.results[]?
```

```
| [
```

```
.check_id,
```

```
.path,
```

```
.start.line,  
.end.line,  
.extra.message  
]  
| @tsv  
'$R/section4-solr-semgrep-taint-results.json' \  
| tee "$R/section4-solr-semgrep-taint-summary.tsv"  
  
jq -r '  
.results[]?  
| "\n==== " + .path + ":" + (.start.line|tostring) + "====\n" + (.extra.lines // "")  
'$R/section4-solr-semgrep-taint-results.json' \  
| tee "$R/section4-solr-semgrep-taint-snippets.txt"
```